Incident Response Policy

Document control	
Company	LogistiComp S.A.
Document ID	LC-POL-003
Version	2.2
Classification	Internal – may be shared with customers under NDA
Owner	Chief Information Security Officer (CISO)
Approved by	Information Security Steering Committee (ISSC)
Effective date	15 January 2026
Next review	January 2027

1. Purpose

This policy defines how LogistiComp S.A. detects, reports, handles and learns from information security incidents, so that their impact on customers and on the Company is kept as small as possible. It also sets the Company's obligations for notifying customers and authorities. It implements Section 15 of the Information Security Policy (LC-POL-001).

2. Scope

This policy applies to all LogistiComp personnel and to all information, systems and services of the Company, including the LogistiComp WMS production environment, corporate IT systems and suppliers that process data on the Company's behalf.

3. Definitions

- **Security event:** an observable occurrence that may indicate a breach of security, for example a failed login, a malware alert or an unusual data transfer.
- **Security incident:** a security event, or a series of events, that actually or very likely compromises the confidentiality, integrity or availability of LogistiComp information or systems.
- **Personal data breach:** a security incident that leads to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data, as defined in the GDPR.
- **Confirmed incident:** an incident whose occurrence has been verified by the Incident Manager on the basis of evidence.

4. Roles and Responsibilities

- **Incident Manager:** the CISO or, outside business hours, the on-call security lead. The Incident Manager leads the response, decides the severity and decides when the incident is closed.
- **Incident Response Team (IRT):** convened by the Incident Manager according to the incident. Its core members are the CISO, the on-call site reliability engineer, the responsible engineering lead, the Data Protection Officer (DPO), the Head of Customer Operations and the Company's legal counsel. The Head of Communications joins when external communication is needed.
- **Managed SOC provider:** monitors the SIEM 24 hours a day, 7 days a week, analyses alerts and escalates suspected incidents to the on-call security lead.
- **All personnel:** must report suspected incidents immediately and must not try to investigate them on their own.

5. Reporting an Incident

- Personnel must report any suspected security incident **immediately** to security@logisticomp.example or by calling the 24/7 security on-call line.
- Customers can report suspected security issues through the LogistiComp support portal or to security@logisticomp.example. Reports from customers are triaged by the security team.
- Personnel must not delete evidence, contact suspected attackers or discuss the incident outside the IRT.

6. Severity Levels

Each incident is assigned a severity level, which can be changed as more information becomes available.

Severity	Description	Response starts within	IRT convened
SEV1 – Critical	Confirmed unauthorised access to or loss of Restricted data, or a complete outage of LogistiComp WMS	15 minutes	Within 1 hour
SEV2 – High	Likely compromise of Restricted data, compromise of a privileged account, or a major degradation of LogistiComp WMS	1 hour	Within 4 hours
SEV3 – Medium	Limited compromise without impact on customer data, for example a malware infection on a single laptop	4 business hours	As needed
SEV4 – Low	Minor policy violation or suspicious activity without confirmed impact	Next business day	Not required

7. Incident Response Process

LogistiComp follows a response process based on NIST Special Publication 800-61.

1. **Preparation:** maintaining the on-call rota, response playbooks, tools and contact lists, and training the IRT.
2. **Detection and analysis:** identifying incidents from SIEM alerts, reports from personnel and customers, and supplier notifications; confirming the incident and assigning a severity level.
3. **Containment:** limiting the damage, for example by isolating affected systems, disabling compromised accounts or blocking malicious network traffic.
4. **Eradication:** removing the cause of the incident, such as malware or an exploited vulnerability.
5. **Recovery:** restoring affected systems and data from trusted sources, and monitoring them closely to confirm normal operation.
6. **Post-incident review:** analysing what happened and what can be improved (see Section 11).

All actions and decisions taken during an incident are recorded in the incident ticket with the time they were taken.

8. Evidence Handling

Evidence such as logs, disk images and memory captures is preserved and protected from modification, and a chain of custody is kept for every item of evidence. LogistiComp has a retainer agreement with an external digital forensics firm, which supports the IRT in SEV1 incidents and whenever specialist analysis is needed.

9. Customer Notification

If a confirmed incident affects a customer's data, LogistiComp notifies the customer's designated security contact **within 48 hours of the incident being confirmed**. The notification describes, as far as is known at the time:

- the nature of the incident and when it happened;
- the categories and approximate volume of affected data;
- the likely consequences;
- the measures taken or proposed to address the incident and reduce its effects;
- a contact person at LogistiComp for further information.

Affected customers receive updates as the investigation progresses: at least every 24 hours for SEV1 incidents. After the incident is closed, they receive a written incident report within 15 business days.

10. Regulatory Notification

LogistiComp's obligations depend on its role under the GDPR:

- **LogistiComp as processor:** for personal data that LogistiComp processes on behalf of its customers in LogistiComp WMS, the customer is the controller. LogistiComp notifies the affected customer of a personal data breach without undue delay and within the 48 hours stated in Section 9, and gives the customer the information and assistance it needs to meet its own notification obligations. The customer, as controller, decides whether to notify the supervisory authority and the affected individuals.
- **LogistiComp as controller:** for personal data that LogistiComp processes for its own purposes, such as employee data and customer contact data, the DPO notifies the Hellenic Data Protection Authority **within 72 hours** of the Company becoming aware of a personal data breach, unless the breach is unlikely to result in a risk to the rights and freedoms of individuals. If the breach is likely to result in a high risk to individuals, they are also informed without undue delay.

The decision to involve law enforcement authorities is made by the CEO together with legal counsel.

11. Post-Incident Review

A post-incident review is held within 10 business days of closing every SEV1 and SEV2 incident. The review establishes the root cause, what worked well and what did not, and defines corrective actions with owners and due dates. Corrective actions are tracked to completion by the CISO, and a summary of SEV1 and SEV2 incidents is reported to the ISSC every quarter.

12. Communication

Only the CEO, or a person authorised by the CEO, may make public statements about a security incident. All external communication, apart from customer notifications under Section 9, must be approved by the CEO and legal counsel.

13. Testing and Training

The incident response process is tested at least once a year through a tabletop exercise based on a realistic scenario, such as a ransomware attack or a leak of customer data. Members of the IRT receive incident response training annually. Lessons from exercises are handled in the same way as those from real incidents.

14. Records

All security incidents are recorded in the incident register, together with their severity, timeline, actions taken and the results of the post-incident review. Incident records are kept for 3 years.

15. Review

This policy is reviewed at least annually by the CISO and approved by the ISSC, and also after any SEV1 incident.